

SC EXAM PREP — PREDICTED 2026

AIセキュリティ・LLM

OWASP Top 10 for LLM／プロンプトインジェクション／RAG／AIエージェント／MITRE ATLAS。「出る出ると言われ続けて未出題」の最有力テーマを5問で体系学習する。

Q1・LLM01

間接プロンプトインジェクション

頻出 ★★★

Q2・LLM05

不適切な出力処理
→XSS/SQLi連鎖

頻出 ★★★

Q3・Framework

MITRE ATLAS の位置づけ

頻出 ★★★

Q4・LLM08

ベクトルと埋め込みの脆弱性

頻出 ★★★

Q5・LLM06

過剰な代理権限(AIエージェント)

頻出 ★★★

 基礎概念 5枚  問題演習 5問  統合サマリー  2026 春・秋 想定

※ 過去問傾向(令和3～7年)と最新動向をもとにAIが作成した予想問題です。実際の試験問題ではありません。最終確認を推奨します。



学習マップ — 5問の相互関係

攻撃の「経路」と「フェーズ」で切り分ける学習動線

MAP

Q1

間接PI

外部データ(Web/メール/PDF)に指示を潜ませ、利用者を介さず実行

LLM01 / 直接PIと対比



Q2

出力処理

LLM出力を無検証で下流へ→XSS/SQLi/コマンドインジェクションに連鎖

LLM05 / Webセキュ接続



Q3

ATLAS

攻撃TTPを体系化。ATT&CKのAI版。RMF/42001と区別

Framework / 定義問題



Q4

ベクトルDB

RAGの権限フィルタ不備→他部署・他テナント文書が漏えい

LLM08 / RAG分離



Q5

過剰権限

エージェントの権限・自律性が過大→注入指示で高影響操作まで実行

LLM06 / 最小権限

STEP 1 | WHY

OWASP LLM Top10 と攻撃分類(経路×フェーズ)の全体像を理解する

STEP 2 | HOW

5問で「どのLLMリスクか」を判別し、ひっかけ選択肢を切る

STEP 3 | WHAT

空-雨-傘で対策(分離・最小権限・出力エスケープ・権限フィルタ)へ落とす

① 基礎概念 — OWASP LLM Top10 分類マップ

攻撃の「経路」と「フェーズ」の2軸で本デッキ5問を配置

CONCEPT

軸 / リスク	学習時(Training)	推論時・入力(Inference / Input)	出力・下流(Output / Downstream)
利用者入力 経由	—	直接プロンプトインジェクション(LLM01)/ジェイルブレイク	Q2 不適切な出力処理(LLM05) →XSS/SQLi/コマンドインジェクション/SSRF
外部データ 経由	データ/モデルのポイズニング(LLM04)	Q1 間接プロンプトインジェクション(LLM01)	
検索・データ層	Q4 ベクトルと埋め込みの脆弱性(LLM08)/機密情報漏えい(LLM02)		システムプロンプト漏えい(LLM07)/誤情報(LLM09)
エージェント / 資源	Q5 過剰な代理権限(LLM06)		無制限消費(LLM10)

核心: LLMリスクは「①どこから入るか(利用者入力/外部データ/検索層/ツール)」と「②いつ起きるか(学習時/推論時/出力時)」の2軸で切り分けられる。**Q3のMITRE ATLAS**は、この攻撃TTP全体を体系化するナレッジベースとして俯瞰の役割を担う。

② 基礎概念 — 混同しやすい概念 比較表

似て見えるが「経路・フェーズ・対策」が異なる5ペア

CONCEPT

対象概念	● 概念A	● 概念B (混同パターン)
PIの経路	直接PI：利用者が入力欄に「指示を無視せよ」と自ら注入	間接PI：Web/メール/PDF等外部データに潜む指示をLLMが読み込み実行
攻撃フェーズ	回避攻撃(敵対的サンプル)：推論時に微小摂動で誤分類	データポイズニング：学習時にデータ汚染でバックドア
出力の扱い	LLM出力を信頼境界の外側として出力時にエスケープ(LLM05対策)	入力のエスケープだけで対策したつもり＝出力処理漏れでXSS成立
データ復元系	モデル反転／メンバーシップ推論：出力から学習データを推定	モデル抽出(窃取)：大量クエリでモデル機能を複製
エージェント統制	最小権限＋高影響操作に人間承認(HITL)	全ツールをLLM判断で自動実行＝過剰な代理権限(LLM06)

③ 基礎概念 — 必須用語集

AIセキュリティ5問を解く8用語

CONCEPT

プロンプトインジェクション Prompt Injection

指示とデータを同一チャンネルで処理する性質を突き、意図しない指示を実行させる。利用者入力経由=直接、外部データ経由=間接。

 OWASP LLM01:2025

ベクトルと埋め込みの脆弱性 Vector & Embedding

RAGのベクトルDBのアクセス制御不備・テナント分離不足で横断の情報漏えい。埋め込みからの元データ復元も。

 OWASP LLM08:2025

MITRE ATLAS

ATT&CKをAI/機械学習向けに拡張し、攻撃戦術×技法(TTP)を実事例で体系化したナレッジベース。脅威分析の共通言語。

 ATT&CK の AI 版

ジェイルブレイク Jailbreak

言い回しやロールプレイでガードレール(安全機構)を回避し、禁止された出力を引き出す。

 ガードレール回避

不適切な出力処理 Improper Output Handling

LLM出力を無検証で下流(ブラウザ/DB/OS/API)へ渡し、XSS・SQLi・コマンドインジェクション・SSRF・RCEに連鎖。

 OWASP LLM05:2025

過剰な代理権限 Excessive Agency

エージェントの機能・権限・自律性が過大で、誤動作や注入成立時の被害が拡大。最小権限+人間承認が定石。

 OWASP LLM06:2025

敵対的サンプル / 回避攻撃 Adversarial / Evasion

推論時に人間には知覚しにくい微小な摂動を入力へ加え、分類器に誤分類を起こさせる。

 推論時攻撃

human-in-the-loop HITL

影響の大きい/不可逆な操作(外部送信・削除・決済)の実行前に人間の承認を挟む統制。

 LLM06 の定番対策

④ 基礎概念 — フレームワーク・規格マトリクス

CONCEPT

「攻撃TTP／防御／リスク管理／認証規格」を混同しない

名称	種別	要点（試験での問われ方）
MITRE ATLAS	攻撃TTPの体系化	ATT&CKのAI版。「戦術×技法」でAIへの攻撃を整理。 Q3の正解 。攻撃側の知識ベース。
MITRE ATT&CK	攻撃TTPの体系化(汎用)	実観測の攻撃者の振る舞い(TTP)を分類。ATLASの母体。第5分野(攻撃・IR)と接続。
MITRE D3FEND	防御技術の体系化	対策側 のマッピング。攻撃TTPの体系化ではない=Q3のひっかけ。
NIST AI RMF	リスク管理FW	GOVERN/MAP/MEASURE/MANAGEでAIリスクを管理。攻撃TTP体系ではない。
ISO/IEC 42001	認証規格(AIMS)	AIマネジメントシステムの認証規格。ISMS(27001)のAI版という位置づけ。
AI事業者ガイドライン	国内ガイドライン	総務省・経産省。開発者/提供者/利用者の3主体区分。組織統制の根拠。

💡 **頻出の軸:** 「攻撃を体系化=ATLAS/ATT&CK」「防御を体系化=D3FEND」「リスク管理=AI RMF」「認証規格=ISO/IEC 42001」。この4分類の取り違えが4択のひっかけの定番。



試験のコツ & 頻出ひっかけ

Exam Strategy & Common Pitfalls

TIPS

✓ 解くコツ

1. PIは**経路**で判別。利用者入力=直接／外部データ(Web・メール・PDF・検索結果)=間接。
2. LLM05は「**出力**を信頼境界の外側として扱う」。対策は**出力時**のエスケープ／サニタイズ。
3. フレームワークは4分類で暗記：攻撃=ATLAS/ATT&CK、防御=D3FEND、管理=AI RMF、規格=42001。
4. エージェント問題は**最小権限** + **HITL(人間承認)** + **監査ログ**が正解語彙。

⚠ よくあるひっかけ

- LLM05を「**入力**のエスケープ」で対策したつもり→出力処理漏れでXSS成立。
- 「大量クエリでコスト増」=LLM10無制限消費。PIやポイズニングと混同しない。
- 回避攻撃(推論時)とポイズニング(学習時)の**フェーズ取り違い**。
- エージェント対策で「自動実行で速度優先」「システムプロンプトを応答に含める」は**逆効果**。

合言葉: 「経路(どこから)×フェーズ(いつ)」で分類 → 対策は「**分離**・**最小権限**・**出力エスケープ**・**権限フィルタ**・**人間承認**」の5語彙に集約される。

OWASP Top 10 for LLM 2025 における「間接プロンプトインジェクション」に該当する攻撃はどれか。

ア 入力欄に「これまでの指示を無視せよ」と直接打ち込み制約を解除させる

イ 公開Webページやメール本文に視認しにくい指示文を埋め込み、RAGや要約でLLMに実行させる

ウ APIに大量かつ長大な推論要求を送り、応答遅延とコスト増を起こす

エ 学習用データに悪意あるサンプルを混入させバックドアを仕込む

正解 イ ア=直接PI(LLM01)/ウ=無制限消費(LLM10)/エ=データ・モデルのポイズニング(LLM04)

🔵 空 (事実)

利用者の直接入力ではなく、LLMが処理対象として取り込む外部データに指示が潜んでいる。

🔴 雨 (解釈)

利用者を介さず実行される点が「間接」の核心。指示とデータを同一チャネルで処理する構造が原因。

🟢 傘 (対策)

取り込む外部データを検証・無害化し、指示とデータを分離。要約対象データにツール実行権限を与えない。

OWASP LLM05:2025 「不適切な出力処理」に起因する被害として最も適切なものはどれか。

ア LLM生成のHTML/スクリプトを無検証で埋め込み格納型XSS、あるいは生成文字列をそのままOS/SQLに渡しコマンド/SQLインジェクションに連鎖

イ MFAの時刻同期ずれでOTP検証に失敗し正規利用者がログイン不可

ウ ベクトルDBのアクセス制御不備で他テナント文書が検索結果に混入

エ エージェントに過大なツール権限を与え意図しない外部操作が行われる

正解 ア イ=認証運用の可用性問題(LLM無関係)/ウ=LLM08/エ=LLM06

☀ 空 (事実)

LLM出力を検証せず、下流のブラウザ・DB・OS・APIへそのまま渡している。

☁ 雨 (解釈)

LLM出力 = 信頼できない外部入力。既存のインジェクション脆弱性(XSS/SQLi/RCE)へ連鎖する。

☂ 傘 (対策)

出力を信頼境界の外側として扱い、出力時にコンテキスト依存のエスケープ/サニタイズ + CSP。

👜 実務メモ: ここは既存Webアプリセキュリティ(第3分野)と直結する午後の狙い目。「入力エスケープ」ではなく出力エスケープと書けるかが分水嶺。

AIシステムへの攻撃を体系化したナレッジベースであり、MITRE ATT&CK の考え方をAI/機械学習システムの攻撃戦術・技法(TTP)に拡張したものはどれか。

ア MITRE D3FEND

イ MITRE ATLAS

ウ NIST AI RMF

エ ISO/IEC 42001

正解 イ ア=防御技術の体系化/ウ=リスク管理FW/エ=AIMS認証規格

🏠 空 (事実)

「戦術×技法」マトリクス形式で、AI/MLへの攻撃TTPを実事例に基づき整理したもの。

🌧️ 雨 (解釈)

ATT&CKの“AI版”。攻撃を体系化=ATLAS、防御=D3FEND、管理=RMF、規格=42001の4分類で判別。

☂️ 傘 (対策)

脅威分析・検知/対策検討の共通言語として活用。CSIRTのインシデント整理に用いる。

RAGを用いた社内文書検索チャットボットにおいて、LLM08:2025「ベクトルと埋め込みの脆弱性」として顕在化するリスクはどれか。

ア 回答の根拠が提示されず利用者が誤情報を過度に信頼する

イ ベクトルDBの権限フィルタリング不足で、閲覧権限のない他部署・他テナント文書を
検索取得できる

ウ システム指示が応答に出力され内部構成が推測される

エ 長大コンテキストの投入で推論コストが急増する

正解 イ ア=誤情報(LLM09)/ウ=システムプロンプト漏えい(LLM07)/エ=無制限消費(LLM10)

空 (事実)

RAGのベクトルDBにアクセス制御・テナント分離の不備がある。

雨 (解釈)

埋め込み/検索層固有の脆弱性。横断的な情報漏えい、埋め込みからの元データ復元が中心。

傘 (対策)

検索時に利用者の権限で結果をフィルタリング、部署ごとにインデックス/テナント分離。

LLM06:2025 「過剰な代理権限」を持つAIエージェントのリスクを低減する対策として、最も適切なものはどれか。

ア すべてのツール呼び出しをLLMの判断のみで自動実行し応答速度を最優先

イ ツール・権限・自律性を最小化し、高影響操作(外部送信・削除・決済)の実行前に人間承認(HITL)を挟む

ウ 出力トークン数の上限を撤廃しより詳細な応答を返す

エ システムプロンプトを応答に含めて挙動を検証できるようにする

正解 イ ア=自律性・権限を最大化し逆効果／ウ=LLM10助長／エ=LLM07招く

🔵 空 (事実)

エージェントに与えた機能・権限・自律性が過大。

🔴 雨 (解釈)

誤動作やプロンプトインジェクション成立時に、注入指示が高影響操作まで実行され被害拡大。

🟢 傘 (対策)

最小権限・ツール制限 + 不可逆/高影響操作への人間承認 + 操作の監査ログ化。



午後 記述式 — シナリオ要点

RAGチャットボット導入／AIエージェント・ガバナンス

記述

◆ 問1 (秋想定) 社内RAGチャットボット

- 単一インデックス・権限チェック無し → **LLM08**。対策=検索時の権限フィルタ + インデックス分離。
- 外部PDFの指示で顧客リスト出力 → **間接プロンプトインジェクション**。原因=外部データを検証せずシステムプロンプトへ連結(指示とデータ未分離)。
- 生成結果をHTMLに無検証埋め込み → **格納型XSS**。対策=出力エスケープ + CSP。

◆ 問2 (春想定) AIエージェント・ガバナンス

- 社外へファイル送信の直接要因 = **LLM06 過剰な代理権限** + **LLM01 間接PI**の2軸。
- 対策 = 最小権限・HITL(高影響操作の事前承認)・指示とデータの分離。
- **MITRE ATLAS** = ATT&CKのAI拡張で攻撃TTPを体系化した共通言語。
- 組織統制 = 入力禁止情報の規程化 / シャドーAI禁止(承認制)。

採点の分水嶺: ①「間接」PIと明示 ②「出力時」エスケープ ③エージェントは**最小権限 + HITL** ④組織統制は**入力禁止情報の規程化・シャドーAI防止**まで踏み込めているか。



統合サマリー — 頻出ヒートマップ & 総括

出題可能性 × 難易度でAIセキュリティ論点を俯瞰

SUMMARY

論点	出題可能性	難易度	対策語彙
間接プロンプトインジェクション(LLM01)	最有力	中	指示/データ分離
不適切な出力処理(LLM05)	最有力	中	出力エスケープ
過剰な代理権限(LLM06)	最有力	高	最小権限 + HITL
ベクトル/埋め込み(LLM08)	高	中	権限フィルタ/分離
MITRE ATLAS / RMF / 42001	高	低	4分類で暗記

総括: AIセキュリティは**午前IIの用語定義**(ATLAS・敵対的サンプル・ジェイルブレイク等)と、**午後の実務シナリオ**(RAG・AIエージェント)の両方で狙われる。既存のWebセキュリティ知識(XSS/SQLi)と接続する**LLM05**、エージェント時代の目玉**LLM06**を最優先で固めること。

※本デッキはAIが過去問傾向・最新動向をもとに作成した予想問題です。正解・解説・図解は最終確認を推奨します。